INDUSTRY THREAT HUNT · ARTIFICIAL INTELLIGENCE

THE SHADOW API ECONOMY

The largest threat to AI providers in this dataset is not phishing or malware. It is a **parallel distribution economy** — roughly **5,600 unauthorised gateway deployments** reselling access to commercial models, built on off-the-shelf software, with a price-comparison layer and a **~100% survival rate**. Nobody is taking it down, because nobody is classifying it as abuse.

Source: Webamon passive web-scan data ~5,600 gateway deployments 904 relay marketplaces verified live 2026-08-01

5,623 unauthorised AI API gateway deployments	**30×** growth in subscription-resale gateways since January
47 price-comparison sites serving the grey market	**100%** of the relay market still hosting when probed

01 KEY JUDGEMENTS

HIGH A **productised grey market** resells access to commercial AI models at scale. Three named platforms account for the bulk of it — `New API` (3,934 domains), `Sub2API` (1,127) and `One API` (562). These are deployable software packages, not bespoke builds, which is why the market scales the way it does.

HIGH The market's core mechanic is **subscription-to-API conversion** — pooling consumer subscription accounts and re-exposing them as metered API endpoints. Platform copy states it plainly: "*smart routing across multiple upstream accounts with automatic failover.*"

HIGH The ecosystem is **commercially mature**, not experimental. It has **47 dedicated price-comparison and directory sites** — including services offering "真假检测" (authenticity testing) of relay providers. Markets only build comparison shopping when they have competition and repeat customers.

HIGH **Enforcement is effectively absent.** Of the relay marketplaces, aggregators and Sub2API gateways probed, **100% were still hosting**. This infrastructure does not trip brand-protection monitoring because it rarely impersonates a brand — it *resells* one.

HIGH The market is **overwhelmingly Chinese-language and Chinese-operated**, and its growth is a **step change in March 2026** — Sub2API **18.7×** and relay stations **19×** month-over-month — not a gradual ramp. It has plateaued since at roughly ten times the January baseline.

MODERATE The structural driver is **access restriction**. US export controls and provider-level geo-blocking leave a large developer population with real demand and no lawful direct channel; a relay market is the predictable arbitrage. **We have not tied the March step change to a specific dated policy action** — see §03 for what is and is not established.

MODERATE A separate, conventional threat layer targets AI users directly: **420 domains** impersonating OpenAI properties, **245 punycode homographs** of a single vendor (Moonshot AI), and **108 fake installer** pages.

02 FINDING 1 — AN INDUSTRIALISED RESALE MARKET

Chinese-language operators call these 中转站 — "relay stations". They sit between the customer and the model provider, selling metered access at a steep discount to list price.

Platform deployments observed

Counted by the platform's own default page title — these are self-identifying deployments, not inferred.

Growth through 2026

New API deployments rose **15×** between January and May. Sub2API — the subscription-conversion platform specifically — rose **30×** and was still climbing in July.

> **What the platforms say they do.** One gateway describes itself as a "*Subscription to API Conversion Platform*" offering "*a single API key to call all connected AI models — no separate applications needed*", with "*smart routing across multiple upstream accounts with automatic failover*". Read plainly: consumer subscriptions, pooled, load-balanced, and resold as developer infrastructure.

03 FINDING 2 — THE CHINA NEXUS AND THE MARCH INFLECTION

The market is overwhelmingly Chinese-language and Chinese-operated, and its growth is not gradual. It steps sharply in **March 2026** and never returns to the prior baseline.

Month-over-month growth multiple

New gateway domains observed per month, by platform.

	JAN	FEB	MAR	APR	MAY	JUN	JUL
All gateways	115	135	**595**	940	1,845	1,349	1,325
New API	84	105	**362**	645	1,264	914	753
Sub2API	11	7	**131**	131	301	249	336
Relay stations	10	2	**38**	81	128	96	91

February → March step change: Sub2API **18.7×**, relay stations **19×**, all gateways **4.4×**. Growth continues to a May peak, then plateaus at roughly ten times the January baseline.

Where the operators sit

Interface language is predominantly Simplified Chinese. Hosting shows the classic China-adjacent pattern — **Hong Kong (808)**, **Singapore (618)**, Japan, South Korea and mainland China — with **Tencent Cloud** and **Alibaba** both inside the top six ASNs.

The plurality of scans still resolve to US infrastructure (2,521), almost entirely **Cloudflare-fronted**. That is origin obfuscation, not US operation: the storefront is on a Western CDN, the audience and language are not.

The demand-side context: access restriction. Since 2022 successive US export controls have restricted advanced AI compute to China, and the 2025 "AI Diffusion" framework extended that thinking to model weights before being rescinded. Independently, major US providers geo-restrict China at the commercial level — OpenAI withdrew API access to mainland China in mid-2024, and other frontier vendors exclude it under their usage policies.

The net effect is a large, sophisticated developer population with **genuine demand and no lawful direct channel**. A relay market is the predictable arbitrage: it exists precisely because the front door is closed. That is the structural tailwind behind every number in this report.

WHAT WE CAN AND CANNOT CLAIM

1. **Established from our data:** the March 2026 step change is real, sharp and simultaneous across three independent platforms. It is not an artifact of scan volume — the platforms are counted by their own self-identifying page titles.
2. **Established externally:** the export-control and geo-restriction regime described above creates persistent unmet demand in this market.
3. **NOT established:** that any *specific* regulatory action caused the March inflection. Passive scan data cannot demonstrate that link, and we have not tied the step change to a dated policy event. **Recommended next step:** overlay the Q1 2026 BIS / Entity List and provider policy-change calendar against this series — if a measure lands in late February or March, the correlation becomes materially stronger. Until then this is a documented coincidence in timing, not a causal finding.

04 FINDING 3 — THE MARKET HAS A PRICE-COMPARISON LAYER

The clearest evidence of maturity. **47 domains** exist solely to rank, compare and vet relay providers — the grey-market equivalent of a price-comparison site.

SERVICE TYPE	OBSERVED PAGE TITLES (TRANSLATED)
Directories	"AI API relay-station navigation — find the cheapest, most stable ChatGPT / Claude relay"
Price comparison	"AI relay-station price comparison — find the cheapest, fastest, most stable"
Authenticity testing	"API Pure — relay-station authenticity detection / comparison / recommendation platform"
Rankings	"Relay Radar", "1xAPI — transparent pricing AI relay station"

Why "authenticity testing" is the most telling detail. A service exists to test whether a relay is *genuinely* serving the model it claims. That implies a known sub-population of relays which take payment and silently substitute a cheaper model — fraud *within* the grey market. This is a layered economy with its own trust problem, not a fringe activity.

05 RISK ASSESSMENT

The resale market is usually framed as a licensing matter. The security consequences are more serious than the revenue ones.

CRITICAL	**Enterprise data exposure.** Every prompt and completion routed through a relay passes through an unaccountable third party. A developer who integrates a cheap gateway silently places their organisation's inputs — source code, customer records, internal documents — inside someone else's logging pipeline. The user believes they are talking to the model vendor.
CRITICAL	**Upstream account compromise.** "Multiple upstream accounts with automatic failover" requires a supply of accounts. That demand is met by stolen credentials, carded subscriptions and fraudulently created accounts — making every model provider's consumer tier a target for account-takeover at scale.
HIGH	**Safety and policy bypass.** A relay controls the request path and can strip system prompts, disable moderation calls, or misrepresent which model answered. Provider-side safety commitments cannot be enforced through infrastructure the provider does not operate.
HIGH	**Software supply chain.** Because relays are OpenAI-API-compatible, adoption is a one-line base-URL change. Cheap gateways can propagate into production systems and CI pipelines with no procurement review and no visible signal.
MODERATE	**Revenue leakage and attribution loss.** Usage is invisible to the provider, and abuse originating through a relay is attributed to the pooled account rather than the actual user.

06 FINDING 4 — THE CONVENTIONAL THREAT LAYER

Alongside the resale economy sits recognisable brand abuse aimed at users rather than at the provider's business model.

IDN homograph attack on a single vendor

245 punycode domains targeting **Moonshot AI** — `xn--moonshot-03a`, `xn--moonsht-60a`, `xn--moonshos-uxb` and variants, registered across `.com .net .app .xyz`.

The concentration on one vendor is unusual and suggests a targeted campaign rather than opportunistic squatting. Several already carry Cloudflare's "*Suspected phishing site*" interstitial.

OpenAI property impersonation

420 domains on `openai-*` / `chatgpt-*` patterns. The higher-signal examples clone product surfaces rather than marketing pages:

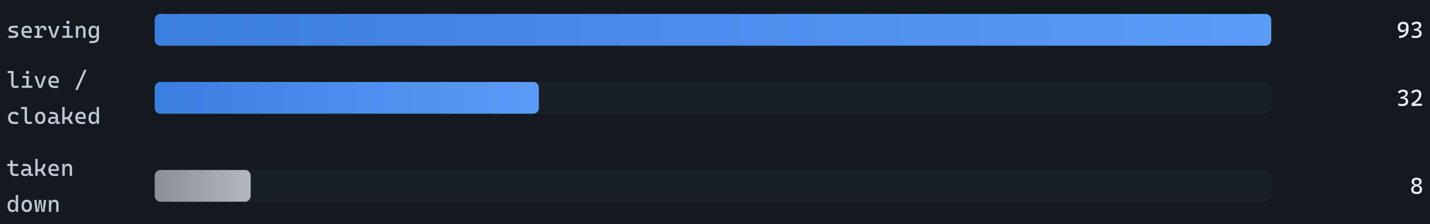
`platform-chatgpt[.]com` — "Create an account"
`chatgpt-staging[.]com` — "Sign in to your account"
`openai-helpdesk[.]com` — clones the genuine corporate title
`codex-ambassador[.]com` — impersonates a developer programme

An honest negative. Telegram and Discord exfiltration — ubiquitous in crypto and government-themed phishing — is almost entirely **absent** here, appearing on a single AI-branded domain across the whole corpus. AI-sector abuse is overwhelmingly **commercial**, not credential-harvesting. Controls designed around infostealer delivery will not engage with this threat.

07 ENFORCEMENT REALITY

Live status of the confirmed set

133 representative domains, probed DNS → TCP → TLS → HTTP on 2026-08-01.



125 of 133 (94%) still hosting. Relay marketplaces, Sub2API gateways and aggregators were all at **100%**.

Why it survives

This infrastructure is invisible to the controls the industry actually runs:

It rarely impersonates a brand, so brand-protection monitoring never fires.

It serves working content, so reputation systems see a functioning site.

It is not malware, so endpoint and URL blocklists have no reason to act.

The only parties who can see it are the model providers themselves — and only if they look for resale infrastructure rather than for phishing.

08 DETECTION PACK

Standing hunt queries — Webamon scans index

```
# Gateway platform deployments — self-identifying default titles
page_title:"New API"   OR   page_title:"Sub2API"   OR   page_title:"One API"

# Relay marketplaces (Chinese-language "relay station")
page_title:("中转站" OR "中转 API") AND page_title:(API OR openai OR claude OR gpt)

# The aggregator / price-comparison layer
page_title:"中转站" AND page_title:(导航 OR 比价 OR radar)

# Subscription-pooling language
dom:("Subscription to API" OR "upstream accounts" OR "订阅转API" OR "账号池")

# IDN homographs of your own brand
domain_name:xn--* AND page_title:"<your brand>"

# Product-surface impersonation, not marketing pages
domain_name:(openai-* OR chatgpt-*) AND page_title:(login OR "sign in" OR account)
```

High-value indicators

Numeric .xyz domains hosting an API gateway — the relay market's dominant registration pattern (e.g. six-digit SLDs).

"OpenAI-compatible" in a page title on a domain with no corporate footprint.

Pricing pages quoting per-token rates below provider list price — arithmetically impossible without pooled or stolen upstream access.

Punycode registrations resolving to your brand — 245 against one vendor alone.

09 RECOMMENDATIONS

MODEL PROVIDERS

1. **Monitor for resale, not just impersonation.** Your current brand controls are structurally blind to a site that never claims to be you.
2. **Treat the consumer tier as an attack surface.** Subscription pooling creates direct demand for account-takeover; velocity and concurrency signals on consumer accounts are the detection point.
3. **Fingerprint the gateway platforms.** New API, Sub2API and One API ship recognisable default pages — a standing query, not a research project.

ENTERPRISE SECURITY

1. **Inventory your LLM base URLs.** Any endpoint that is not the vendor's own domain should be treated as a data-egress channel until proven otherwise.
2. **Add relay domains to egress monitoring.** A one-line base-URL change routes prompts through an unknown third party with no other visible signal.
3. **Include AI gateways in procurement review** — "OpenAI-compatible" is not a supplier assurance.

BRAND PROTECTION

1. **Monitor punycode registrations** against your name — this is where the concentrated, targeted activity sits.
2. **Prioritise product-surface clones** (login, account creation, developer programmes) over marketing-page squats.
3. **Re-verify liveness continuously** — 94% of this set survived, so a static list understates exposure rather than overstating it.